

# 儀表板後台管理系統設計說明書

**文件狀態：** 規劃草案，等待規格確認  
**版本：** 0.1  
**日期：** 2026-08-24  
**適用系統：** Teacher Grants Web 儀表板

本文件只提出架構、資料模型、權限與流程設計；目前沒有修改程式碼、CSV 或既有資料。

## 1. 設計目標與邊界

### 1.1 目標

在現有儀表板前增加一個具備身分認證與授權管理的後台，達成：

- 使用者必須以學校帳號密碼，經學校主機認證成功後，才能進入儀表板。
- 系統支援「管理者」、「使用者」、「資料更新者」三種角色。
- 使用者可被授權只能瀏覽指定儀表板。
- 資料更新者可被授權只能更新指定 CSV 資料集。
- 管理者擁有最高權限，但禁止匿名登入；管理者仍必須通過學校身分認證。

### 1.2 現況基礎

目前系統是 Next.js 16 App Router，頁面透過 server loader 直接讀取 `data/` 下的 CSV，再交給 parser 與 dashboard component。既有路由為：

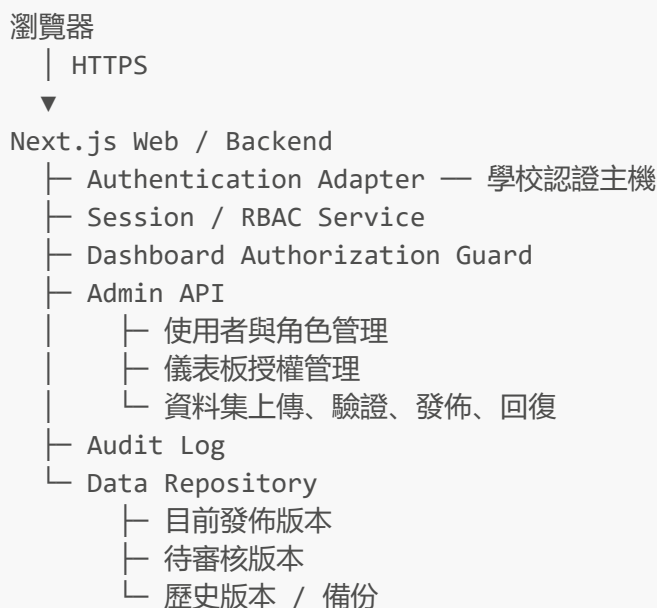
| 儀表板識別    | 路由        | 對應資料集                                                                              |
|----------|-----------|------------------------------------------------------------------------------------|
| grants   | /grants   | grants_112_114.csv                                                                 |
| teaching | /teaching | teaching_awards_114_115.csv                                                        |
| papers   | /papers   | papers_112_114.csv                                                                 |
| projects | /projects | projects_112_114.csv                                                               |
| teachers | /teachers | teachers_114_2.csv、papers_112_114.csv、projects_112_114.csv、patent.csv、transfer.csv |

`teachers` 是跨資料集頁面，因此資料集權限不能只用「一個頁面一個 CSV」簡化處理。

### 1.3 不在本階段決定的事項

- 不直接假設學校主機使用 LDAP、Active Directory、SAML 或 OIDC。
- 不把學校帳號密碼存入本系統。
- 不在本設計階段決定正式資料庫產品、部署主機或網路拓樸。
- 不立即將 CSV 改成資料庫；第一階段可保留 CSV，但必須加上受控更新流程。

## 2. 建議整體架構



## 2.1 認證原則

優先順序建議如下：

1. **OIDC 或 SAML SSO**：若學校已有校務入口或身分服務，優先採用；密碼只在學校認證主機處理。
2. **LDAP/AD 驗證**：若學校提供內網 LDAP/AD，可由後端以安全連線驗證，但不得把 LDAP 密碼寫入資料庫或 log。
3. **學校提供的認證 API**：若學校有既有帳密驗證 API，建立 adapter 封裝，不讓 dashboard route 直接呼叫外部認證。

最後選型須由學校資訊單位確認認證協定、端點、憑證、內外網限制、帳號停權回傳方式與角色群組欄位。

## 2.2 Session 設計

- 認證成功後由本系統建立伺服器端 session，瀏覽器只持有不可讀的 **HttpOnly**、**Secure**、**SameSite=Lax/Strict** session cookie。
- session 內容至少包含：使用者識別、學校帳號、角色、權限版本、建立時間、到期時間、最後活動時間。
- 預設閒置逾時建議 30 分鐘，絕對逾時建議 8 小時；實際值待學校規範確認。
- 登出時要失效伺服器端 session；不得只清除瀏覽器 cookie。
- CSRF 防護、登入失敗節流、帳號停權即時失效與 session rotation 必須納入實作。
- 管理者與資料更新者建議增加 MFA；若學校 SSO 已提供 MFA，沿用 SSO 結果。

## 3. 角色與權限模型

採用 RBAC 加上資源範圍（scope）：角色決定能力，授權範圍決定可操作的儀表板或資料集。

### 3.1 三種角色

| 角色    | 可登入             | 儀表板                    | 資料集      | 使用者/權限管理                    |
|-------|-----------------|------------------------|----------|-----------------------------|
| 管理者   | 必須學校認證，<br>禁止匿名 | 全部                     | 全部       | 全部；可建立/停用帳號、<br>指定角色與 scope |
| 使用者   | 必須學校認證          | 只限被授權項目                | 不可更新     | 不可管理                        |
| 資料更新者 | 必須學校認證          | 建議只讀取被授權儀表板；是否可全部瀏覽待確認 | 只限被授權資料集 | 不可管理                        |

### 3.2 建議權限名稱

- `dashboard:view`: 瀏覽儀表板。
- `dataset:view`: 讀取資料集所產出的儀表板資料。
- `dataset:upload`: 上傳指定資料集新版本。
- `dataset:validate`: 檢視欄位、編碼、資料品質驗證結果。
- `dataset:publish`: 將通過驗證的版本正式發佈。
- `dataset:rollback`: 回復到歷史版本；建議只給管理者。
- `user:manage`: 管理使用者、角色與 scope；只給管理者。
- `audit:view`: 查看稽核紀錄；只給管理者，必要時可另授權稽核人員。

### 3.3 授權判斷規則

每次請求均依序檢查：

1. 是否存在有效 session；沒有則導向登入頁。
2. 帳號是否啟用且未被學校端停權。
3. 是否具備必要角色/權限。
4. 目標儀表板是否在使用者的 dashboard scope。
5. 若是資料操作，目標 dataset 是否在 dataset scope。
6. 寫入操作是否需要額外確認、審核或管理者發佈。

拒絕時回傳 401/403，不以隱藏前端按鈕取代後端授權；前端隱藏只作為使用性改善。

## 4. 後台功能規畫

### 4.1 管理者後台

- 使用者清單：搜尋學校帳號、姓名、部門、角色、啟用狀態、最後登入。
- 使用者詳細資料：角色、可瀏覽儀表板、可更新資料集、有效期間。
- 角色授予與撤銷：所有變更需記錄操作者、時間、前後值。
- 儀表板權限矩陣：管理者可逐項指定 `grants`、`teaching`、`papers`、`projects`、`teachers`。
- 資料集權限矩陣：管理者可逐項指定 7 個 CSV 資料集。
- 資料版本管理：查看目前版本、待發佈版本、歷史版本與驗證結果。
- 稽核查詢：登入、登出、拒絕存取、權限變更、上傳、驗證、發佈、回復。

### 4.2 一般使用者入口

- 登入後只顯示已授權儀表板。
- 直接輸入未授權 URL 必須由 server-side guard 阻擋。

- 顯示目前帳號、角色與登出功能。
- 不顯示資料更新、使用者管理或版本管理入口。

## 4.3 資料更新者入口

建議採「上傳→驗證→預覽→送審/發佈」流程，而不是直接覆蓋 `data/*.csv`：

1. 選擇已授權資料集。
2. 上傳 CSV，限制檔案大小、副檔名與 MIME type。
3. 驗證 UTF-8、表頭、必要欄位、資料型別、年度格式、數字欄位、重複鍵與空白比例。
4. 依現有 parser 先做 dry-run，顯示原始列數、保留列數、排除列數與錯誤明細。
5. 顯示與上一版的筆數、欄位、金額/點數摘要差異。
6. 儲存為待發佈版本；是否可直接發佈由管理者確認。
7. 發佈時建立不可變版本、checksum、操作者與時間紀錄。
8. 發佈失敗不得破壞目前線上版本；可回復上一版。

建議預設：資料更新者可上傳與驗證，但正式發佈需管理者核准。若學校希望資料更新者可自行發佈，應另設定明確 scope，不應由角色名稱自動推導。

## 5. 資料模型草案

本節是後台控制資料的建議模型，不代表現在要建立資料表。

### 5.1 users

| 欄位                                                | 說明                                          |
|---------------------------------------------------|---------------------------------------------|
| <code>id</code>                                   | 系統內部 UUID                                   |
| <code>school_account</code>                       | 學校帳號，唯一；不存密碼                                |
| <code>display_name</code>                         | 顯示名稱，來源可由學校認證主機提供                           |
| <code>department</code>                           | 單位，若認證主機提供                                  |
| <code>status</code>                               | <code>active</code> 、 <code>disabled</code> |
| <code>last_login_at</code>                        | 最近登入時間                                      |
| <code>created_at</code> 、 <code>updated_at</code> | 建立/更新時間                                     |

### 5.2 user\_roles

`user_id`、`role`、`assigned_by`、`assigned_at`、`expires_at`。同一帳號原則上只配置一個主角色；若日後需要複合角色，可擴充為多角色，但要定義衝突與權限聯集規則。

### 5.3 dashboard\_permissions / dataset\_permissions

建議使用明確的 allow-list：

- `user_id`
- `resource_key`
- `permission` (如 `view`、`upload`、`publish`)

- `assigned_by`
- `assigned_at`
- `expires_at`

管理者的全域權限應由後端 policy 判斷，不要在每個頁面硬編碼一份管理者名單。

## 5.4 `dataset_versions`

| 欄位                                                                                 | 說明                                                                                                                                                        |
|------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|
| <code>id</code>                                                                    | 版本 UUID                                                                                                                                                   |
| <code>dataset_key</code>                                                           | 如 <code>grants</code> 、 <code>papers</code>                                                                                                               |
| <code>file_name</code>                                                             | 對應原始 CSV 名稱                                                                                                                                               |
| <code>storage_path</code>                                                          | 受控儲存位置，不直接暴露檔案系統                                                                                                                                          |
| <code>status</code>                                                                | <code>uploaded</code> 、 <code>validated</code> 、 <code>pending_publish</code> 、 <code>published</code> 、 <code>rejected</code> 、 <code>rolled_back</code> |
| <code>row_count</code> / <code>accepted_count</code> / <code>rejected_count</code> | 驗證摘要                                                                                                                                                      |
| <code>sha256</code>                                                                | 檔案完整性指紋                                                                                                                                                   |
| <code>uploaded_by</code> / <code>published_by</code>                               | 操作者                                                                                                                                                       |
| <code>uploaded_at</code> / <code>published_at</code>                               | 時間                                                                                                                                                        |
| <code>validation_report</code>                                                     | 結構化驗證結果                                                                                                                                                   |

## 6. 既有 CSV 架構的遷移策略

### 第一階段：加上認證與唯讀授權

- 保留現有 parser 與 dashboard component。
- 在所有 dashboard route 增加 server-side session/permission guard。
- 建立後台管理頁、使用者 scope 與稽核紀錄。
- 未登入不再能直接讀取儀表板 HTML 或資料。

### 第二階段：受控資料更新

- 將 CSV 從「直接置換」改成版本化儲存。
- 上傳後先以既有 parser dry-run。
- 通過驗證後才切換一個 `published` 指標或版本指標。
- 建立備份、checksum、回復與差異報告。

### 第三階段：視需求導入資料庫

若資料量、同時更新、查詢效能、歷史追蹤或多人協作需求提高，再評估把 CSV 匯入資料庫。即使導入資料庫，CSV 仍可作為交換格式，但不應再由前端或 route 直接讀取工作目錄中的檔案。

## 7. 安全與稽核要求

- 全程 HTTPS；學校認證端點也必須使用受信任憑證。
- 不保存學校密碼、不把 token 寫入 log、不在錯誤訊息回傳認證細節。
- Cookie 設定 `HttpOnly`、`Secure`、適當 `SameSite`，並防止 session fixation。
- 登入失敗節流、帳號鎖定/風險告警規則由學校資訊單位確認。
- 上傳檔案不可直接以原始檔名執行或公開；需存於受控目錄並使用伺服器產生的檔名。
- CSV 必須做內容驗證，避免公式注入、惡意超長欄位、錯誤編碼與壓縮炸彈類型輸入。
- 下載或匯出資料時重新檢查權限，避免以公開 URL 繞過後台。
- 稽核 log 不記錄密碼、完整 session token 或敏感 CSV 內容；至少保留事件、操作者、資源、結果、IP/裝置資訊與時間。
- 管理者不得建立匿名或共用帳號；若學校端回傳的帳號不存在或已停權，本系統應拒絕建立/使用。

## 8. 非功能需求與驗收標準

### 8.1 非功能需求

- 未登入請求任何儀表板 route 均不得取得儀表板資料。
- 權限變更在重新整理或重新登入後立即生效；停權帳號的既有 session 應可被撤銷。
- 資料發佈具備原子切換；發佈失敗時線上仍使用上一版。
- 每次資料更新可追溯到檔案版本、checksum、驗證結果及操作者。
- 主要認證、授權與資料更新事件可供管理者查詢。

### 8.2 核心驗收案例

1. 未登入進入 `/grants`、`/teachers`，導向登入頁且不回傳 dashboard props。
2. 一般使用者只授權 `/grants`，進入 `/teaching` 得到 403/無權限頁。
3. 資料更新者只授權 `papers`，無法上傳 `grants_112_114.csv`。
4. 管理者沒有學校認證成功結果時，無法以匿名或本地固定帳號登入。
5. 上傳缺少必要欄位的 CSV，產生驗證報告且不影響目前 published 版本。
6. 兩人同時更新同一資料集時，版本與發佈結果不互相覆蓋，且可查到完整稽核紀錄。
7. 回復歷史版本後，儀表板可重新讀取回復版本，且回復動作本身被記錄。
8. 認證主機不可用時，系統不允許匿名 fallback；應顯示服務暫時不可用。

## 9. 待確認規格清單

在開始開發前，請學校/系統負責人確認：

1. 學校主機的認證方式：OIDC、SAML、LDAP/AD、校務 API，或其他方式？
2. 認證主機是否提供姓名、單位、職務、停權狀態與群組資訊？角色是否由本系統管理？
3. 管理者初始建立方式：由學校群組映射、一次性邀請，或由部署人員設定？
4. 管理者是否強制 MFA？資料更新者是否強制 MFA？
5. session 閒置/絕對逾時、登入失敗鎖定與稽核 log 保存年限？
6. 資料更新者是否只能上傳/驗證，還是可直接發佈？
7. `teachers` 這類跨多個 CSV 的儀表板，是否要求所有依賴資料集都取得 view 權限才可進入？建議答案是「是」。
8. CSV 是否仍是正式資料來源？是否需要歷史版本、差異比較、排程匯入或人工審核？
9. 哪些欄位屬於個資/敏感資料，儀表板是否要依角色遮罩姓名、電子郵件或研究內容？
10. 系統部署位置是否能連到學校認證主機？正式環境是否有 HTTPS、備份、監控與災難復原？

## 10. 建議的規格確認順序

1. 先確認學校認證協定與網路可達性。
2. 確認三種角色的預設 scope 與資料更新者是否需要發佈權。
3. 確認 CSV 版本化、審核、回復與備份要求。
4. 確認個資遮罩、稽核保存年限與管理者 MFA。
5. 以上確認後，再產出 API、資料庫 schema、畫面 wireframe 與分階段實作計畫。

**建議決策：** 第一版採「學校 SSO/認證主機 + 本系統伺服器 session + RBAC allow-list + CSV 版本化上傳/驗證/管理者發佈」；在規格確認前，不進程式或資料修改。